Announcement: Be among the first to secure AI coworkers before they act. **Request early access to AI Agent Security.**

14 Password Management Best Practices

May 28, 2026

Author:



Derek A. Smith
Founder, National Cybersecurity Education Center

This blog post covers 14 best practices for password security, including how to create strong passwords, which controls should be put around password usage / storage, and more.

Think passwords will become obsolete? Think again. This might be bad news to most, as passwords remain cumbersome and hard to remember. Plus, just when you do remember them, you're ordered to change them again. And guess what? The new password you come up with is likely to be easily guessed and hackable. Moreover, we're seeing password risks f worsen due to the explosion of non-human / machine accounts, such as service a application accounts, robotic processing automation (RPA), AI agents, and more.

Ask Vera

14 Password Management Best Practices

trusty (but frustrating) old password.

Rarely do I attend a conference where I don't hear someone sharing their supposed "good" password policy advice. You know what I'm talking about; **the password policy usually dictates:**

A minimum length of 8 to 12 characters long, with long passphrases being even better.

At least three different character sets (e.g., uppercase characters, lowercase characters, numbers, or symbols).

Password rotation guidelines. In many cases, users must change their passwords every 90 days or less.

Use of account lockouts for bad passwords, with a limit of five or fewer bad attempts.

Some of the foremost experts continue to repeat this advice.

But this advice is at best, incomplete, and at worst, wrong. Why? Because it's outdated and inadequate cybersecurity advice that was never actually good in the first place.

Users and companies that follow obsolete password security advice are likely increasing their cybersecurity risk, not decreasing it. They're focusing more on compliance with outdated regulatory requirements than on password security principles that actually work.

Research shows us that attackers continue to lean on credential-based attack vectors to reach valuable data and / or log into an account and act illicitly on behalf of a user. Here's what credential and password-related risks look like today:

Stolen credentials were the initial access vector in 22% of breaches, and were involved in 88% of basic web application attacks, specifically.

>300K ChatGPT credentials were observed for sale on the dark web.

Nearly a third of attacks (32%) observed by IBM X-Force included the use of valid credentials to gain initial access.

Yet, many users continue to manage and use passwords in an unsafe way:

Ask Vera

78% of individuals use the same password for more than one account. 4% use it on at least 11.

35% of respondents who experienced a security breach identified weak passwords as the cause of their security breaches. This suggests that simple or easily guessable passwords remain a significant vulnerability for many users.

Businesses must accept that a strong, up-to-date password policy is one of the most important lines of defense against unauthorized access to their critical infrastructure, at least for now. So, in this blog, I'm going to discuss some of the password policies and best practices that every organization should consider implementing.

Cybersecurity Concerns Related to Passwords

Password theft, in which an attacker steals the associated identity, is prevalent. However, it can be prevented or largely mitigated by implementing strong password management policies.

Some common techniques for cracking passwords include:

Performing dictionary attacks: Such attacks typically rely on software that automatically plugs common words into password fields.

Guessing simple passwords: The most popular password is **123456**. The next most popular password is **admin**. Other common choices are **password**, **admin123**, and **12345**.

Taking advantage of password reuse: When one data breach compromises passwords, attackers will then try to use that same login information to compromise users' other accounts. Reusing passwords for email, banking, and social media accounts can lead to identity theft.

Cracking security questions: Many people use the names of spouses, kids, other relatives, or pets in security questions or as passwords themselves. Bad actors can deduce these types of answers with a little research, including on your social media profile. To make matters worse, many sites implement the same security questions and users reuse their security-question answer pairs across sites.

Apply social engineering: These techniques (i.e., phishing, vishing, deepfakes etc.) entail the manipulation of others into performing certain actions or divulging confidential information. Attackers commonly use social engineering tactics to trick targets into disclosing passwords.

Ask Vera

14 Password Management Best Practices

Most users understand the nature of security risks related to easy-to-guess passwords. Password policies are a set of lifecycle rules created to increase password security by encouraging users to create strong, secure passwords, and then properly store and utilize them.

Let's now take a closer look at the modern password security policies and best practices that every organization should implement.

Manage all your enterprise's privileged passwords, keys and secrets with Password Safe.

1. Create A Strong, Long Passphrase

Strong passwords make it significantly more difficult for hackers to crack and break into systems. The US National Institute of Standards and Technology (NIST) recommends **creating long passphrases that are easy to remember and difficult to crack.** The latest recommendations from NIST in Special Publication 800-63B-4 require a 15-character minimum for single-factor passwords (8 with MFA), and a maximum length of at least 64.

One practical recommendation for doing so, from the National Cyber Security Centre in the UK, is to use a password made up of three random words. It can also help to use a password manager (which we will cover in detail later), to generate and securely store long, randomized passwords.

2. Apply Password Encryption

Encryption provides additional protection for passwords, even if cybercriminals steal them. As a password encryption best practice, consider end-to-end encryption that is non-reversible. This way, you can protect passwords in transit over the network.

3. Implement Two-Factor Authentication

Two-factor authentication has become a standard for managing access to organizational resources. Users must use an additional method, along with traditional credentials like username and password, to confirm their identity. They might use a one-time code sent to their mobile device or a personalized USB token to do so. The idea is that with two-factor (or multi-factor) authentication, guessing or cracking the password alone is not enough for an attacker to gain access. Today, FIDO2 should be adopted as the MFA standard to improve phishing resistance and support compliance with a growing number of mandates.

Ask Vera

14 Password Management Best Practices

4. Add Advanced Authentication Methods

Apply advanced methods that are not password-based. For instance, as part of multi-factor authentication, users can leverage biometric verification. Examples include logging in to an iPhone using a thumbprint with Touch ID or face scan with Face ID, or authenticating on a PC with Windows Hello facial recognition. This method allows the system to identify employees by recognizing their faces, fingerprints, voices, irises, or heartbeats.

Where supported, prioritize phishing-resistant MFA based on FIDO2/WebAuthn — including passkeys, which replace passwords entirely with cryptographic keys bound to your device. Passkeys provide a variety of benefits for users; they are easier to remember and highly resistant to phishing or server breaches. This is because they are made up of a system-generated cryptographic key pair. One of the keys is stored privately on your device, while the other is stored on the website, application, etc. where the login takes place. By contrast, passwords are kept completely in centralized databases rather than split into two parts.

5. Don't Use Predictable Dictionary Words

Sophisticated attackers use programs that search through tens of thousands of dictionary words across lots of languages. Avoid using common words, phrases, or predictable sentences to help prevent your business from being a victim of a dictionary attack program.

6. Use Different Passwords for Every Account

If one account is breached, other accounts with the same credentials can easily be compromised. At the enterprise level, single sign-on (SSO) reduces password sprawl by allowing employees to authenticate once to access multiple sanctioned applications, eliminating the temptation to reuse credentials across services.

7. Secure Your Mobile Phone

We commonly use our mobile phones to conduct business, shop, and more. But phones bring up many security concerns. Protect your phone and other mobile devices from threats by securing them with a strong password, fingerprint, or facial recognition.

8. Avoid Periodic Changes of Personal Passwords

A widespread password security practice used to be to force users to periodically (every 90 days,180 days, etc.) change passwords. However, in more recent guidance, NIST says *not* to use a mandatory policy of password changes for personal passwords (note that this guidance doesn't apply to privileged credentials).

Ask Vera

to write the passwords down to keep track of them. Thus, a best practice from NIST is to only ask employees for password change in the case of a potential threat or compromise.

Privileged passwords/secrets, however, should still be routinely rotated, including after every use for the most sensitive access.

9. Change Passwords When an Employee Leaves Your Business

Sadly, it's not uncommon for former, disgruntled employees to become your business's worst enemies. Make it a common practice to change passwords when an employee leaves so that former employees can't hack into your business accounts and wreak havoc.

10. Protect Accounts of Privileged Users

Passwords for privileged user accounts require special protections, such as via privileged access management software. Unlike personal passwords, change privileged credentials regularly—including after every use for highly sensitive credentials. Also, organizations should inject privileged credentials directly into a session, and never reveal them to the end user for a further measure of security through obfuscation.

11. Keep Your Business Offline

Don't put vital company security information on the public internet. Doing so will make it easy for attackers to steal. Also, remove any permissions of applications when you have finished with them.

12. Avoid Storing Passwords

Avoid storing passwords in plaintext, either digitally (e.g., in an Excel spreadsheet) or on paper, as it makes it easier for those with malicious motives to steal this information.

13. Be Vigilant About Safety

No matter how strong your passwords are, external threats can negate your best efforts. Make it as difficult as possible for cybercriminals to get your credentials by using up-to-date anti-malware and vulnerability management solutions. This enables you to harden your systems, preventing and mitigating weaknesses that might allow intruders to enter and/or move around your environment.

Additionally, take precautions to avoid social engineering attacks that would compromise your password. For instance, it's a good idea to double-checking links to login portals that you received in potentially suspicious emails / texts, and only log into your accounts directly from the trusted site's URL.

Ask Vera

14 Password Management Best Practices

remember one password. The password manager stores and creates passwords for your different accounts, automatically signing you in when you log on.

You can think of a password manager as a book of your passwords, locked by a master key that only you know. Some might think that sounds bad because if someone acquires the master password, they have ALL your passwords. But if you've chosen a strong and unique, but easy-to-remember master password, you've established a near-perfect way to protect the rest of your personal passwords from improper access.

Password managers not only store your passwords, but also generate and save strong, unique passwords when you sign up on new websites. That means whenever you visit a website or app, you can pull up your password manager, copy your password, and paste it into the login box. Often, password managers come with browser extensions that automatically fill in your password for you. And because many of the password managers have encrypted synchronization across devices, you can take your passwords with you anywhere—even on your phone.

Password managers are designed to provide you with access to all your passwords in an encrypted format that is not accessible to attackers or malicious software. They can offer significant convenience while providing outstanding protection and ensuring that your information stays private.

Generally, there are two primary types of password managers:

Personal Password Managers: These solutions manage passwords for individual users / employees for access to various applications and services.

Privileged Password Managers (also called Enterprise Password Management solutions): These specialized solutions secure and manage privileged credentials from a centralized, enterprise-wide password safe. Privileged credentials are an organization's most sensitive secrets, providing privileged access for user accounts, applications, and systems. And they can typically cover human (employee / vendor), machine, and non-human (AI agents, etc.) identities. These solutions generally work alongside, or combined with, privileged session management. These combined solutions may be referred to as Privileged Account and Session Management (PASM), which is a foundational pillar of privilege management.

Ask Vera

14 Password Management Best Practices

Stolen or weak passwords are still the most common reason for data breaches, so organizations should carefully examine password security policies and password management. With the best practices I have provided in this blog, you can create an effective password security policy and provide stronger protection against unauthorized access.

For an in-depth look at the ways attackers try to crack passwords and a deep dive into defending against such attacks, check out this blog.

*Address password security risk head-on. Identify hidden risks related to privileged identities, credentials, accounts, and more, with BeyondTrust's **Identity Security Risk Assessment**. Get started today.*

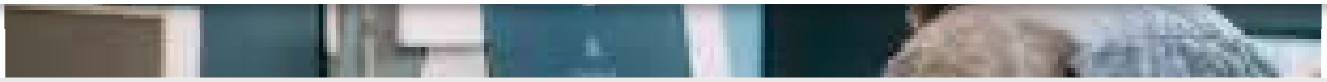
What are the most hacked passwords?

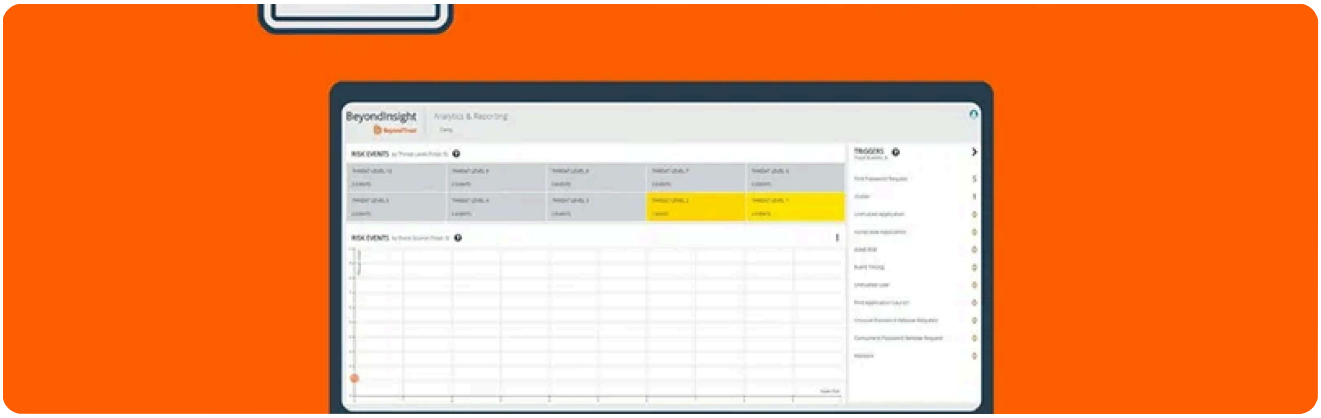
What are some strong password examples?

Documents Blog Videos

Ask Vera

14 Password Management Best Practices





Resources

Password Safe Overview

About the Author



Derek A. Smith

Founder, National Cybersecurity Education Center

Derek A. Smith is an expert at cybersecurity, cyber forensics, healthcare IT, SCADA security, physical security, investigations, organizational leadership and training. He is currently an IT Supervisor at the Internal Revenue Service. He is also owner of The Intercessors Investigative and Training Group (www.theintercessorgroup.com). Formerly, Derek worked for several IT companies including Computer Sciences Corporation and Booz Allen Hamilton. Derek spent 18 years as a special agent for various government agencies and the military. He is also a cyber security professor at the University of Maryland, University College and Virginia University of Science and Technology and has taught for over 25 years. Derek is retired from the US Army and also served in the US Navy, and Air Force for a total of 24 years. He is completing his Doctorate Degree in Organizational Leadership and has completed an MBA, MS in IT Information Assurance, Masters in IT Project Management and a BS in Education. Derek has written several books including Cybersense: The Leaders Guide to

14 Password Management Best Practices

Latest



Jul 28, 2026

WHAM, Bam, Thank You OpenAI for the C2 Infrastructure

Blog 8m



Jul 27, 2026

BeyondTrust + Atlassian Jira: Securing Privileged Access Across Your ITSM Workflows

Blog 6m



Jul 2, 2026

Trusted Execution and Security Boundaries in ServiceNow: How ACLs, Scopes, and Restricted Caller Access Work Together

Blog 5m



Jul 2, 2026

Microsoft Security in 2026: Top Vulnerability Trends from the BeyondTrust Microsoft Vulnerabilities Report

Blog 8m



Jun 24, 2026

Popping Microsoft's Sandbox: Dataverse Security Risks in Plugin Containers

Blog 5m

Related



Mar 18, 2026

What is IT Support? Technical Support Tools & Service Desk Explained

Blog 22m

Ask Vera

14 Password Management Best Practices



Blog 9m

Share this Article

Get the latest news, ideas, and tactics from BeyondTrust. You may unsubscribe at any time.

your.email@company.com* Submit

Products

Solutions

Resources

Free Tools

Ask Vera

14 Password Management Best Practices

Partners

About

Keep up with BeyondTrust

your.email@company.com*

Submit

Customer Support

Get Started

Copyright © 1999 — 2026 BeyondTrust Corporation. All rights reserved. Other trademarks identified on this page are owned by their respective owners. BeyondTrust Corporation is not a chartered bank or trust company, or depository institution. It is not authorized to accept deposits or trust accounts and is not licensed or regulated by any state or federal banking authority.

Ask Vera